Link Github:

https://github.com/thalisonsantos1/Faculdade/tree/main/5%20Periodo/Des%20Sis%20Web%20II/aula1

Relatório: Entendendo e Prevenindo SQL Injection

O que é SQL Injection?

SQL Injection é um tipo de falha de segurança que acontece em sistemas que usam banco de dados. Basicamente, acontece quando um invasor consegue "enganar" o sistema enviando comandos escondidos em campos de formulário, como login, busca ou cadastro.

Imaginemos que temos um formulário de login. Se o sistema não toma cuidado, o invasor pode digitar algo como ' OR '1'='1 no lugar do usuário. Isso faz com que o banco de dados entenda que a senha não importa, e o invasor consegue entrar sem ter conta.

Isso pode ser muito perigoso porque, com essa falha, o invasor consegue:

- Ver dados que não deveria, como informações de outros usuários;
- Apagar ou alterar registros do banco de dados;
- Até mesmo assumir o controle do sistema em casos mais graves.

Por que isso acontece?

O problema principal é quando o sistema junta o código SQL com os dados que o usuário digitou sem fazer nenhum tipo de tratamento. É como se o invasor conseguisse "escrever junto" com o código do programador.

Como o sistema está protegido?

No código foi utilizada uma técnica chamada **prepared statements** (ou consultas preparadas). Funciona assim:

Em vez de montar o comando SQL juntando texto com o que o usuário digitou, eles usam um "espaço reservado" (representado por ?) e depois enviam os valores separados.

Exemplo prático:

Para cadastrar uma pessoa, ao invés de fazer algo como: **"INSERT INTO pessoa VALUES ('" + nome + "', '" + email + "')"**

Foi feito da seguinte maneira:

```
exports.post = async(req, res, next) => {
    try {
        const conn = await connect();
        let {nome, telefone, email} = req.body;

        if (!nome || !telefone || !email) {
            return res.status(400).json({resultado: false, mensagem: 'Nome, telefone e email são obrigatórios'});
        }

        if (!validateEmail(email)) {
            return res.status(400).json({resultado: false, mensagem: 'Email inválido'});
        }

        const sql = 'INSERT INTO pessoa (nome, telefone, email) VALUES (?, ?, ?)';
        await conn.query(sql, [nome, telefone, email]);
        res.status(201).json({resultado: true, mensagem: 'Pessoa inserida com sucesso'});
    } catch (error) {
        res.status(500).json({resultado: false, mensagem: error.message});
    }
};
```

Dessa forma, o banco de dados entende que os valores são apenas dados, e não comandos. Mesmo que o usuário tente digitar algo malicioso, o sistema não executa como código.

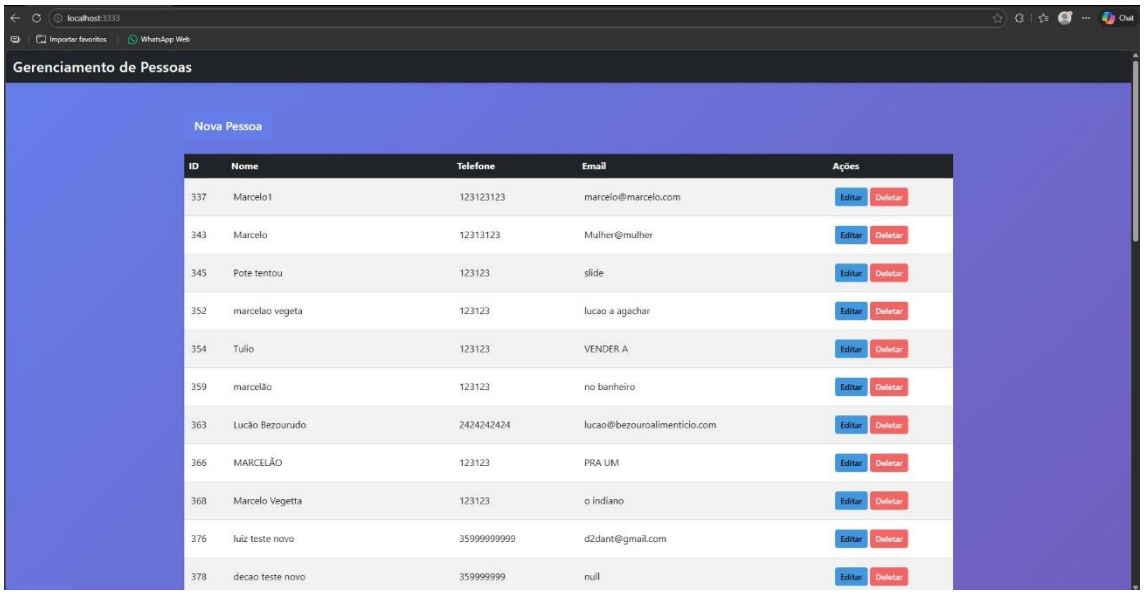
Além disso, é importante destacar que:

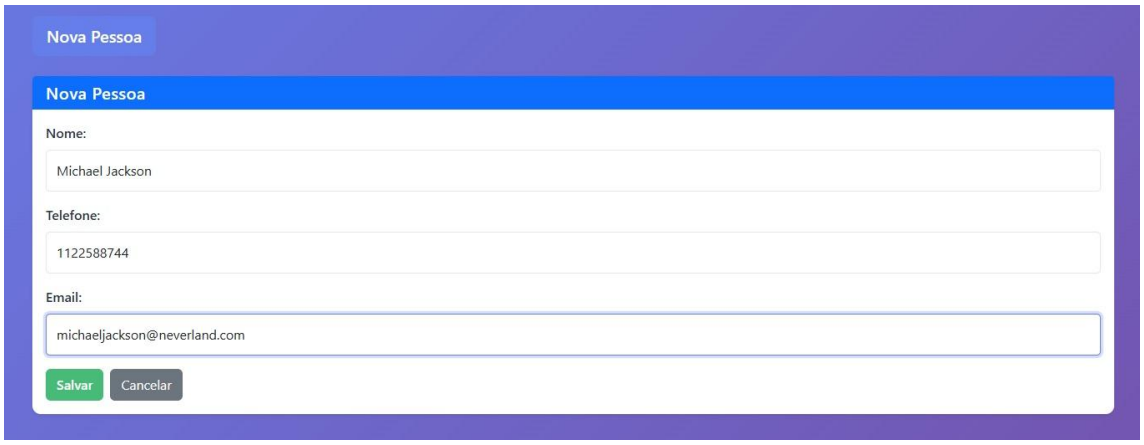
- A biblioteca “mysql2” já tem proteções nativas;
- O código também verifica se os campos obrigatórios foram preenchidos, o que ajuda a evitar problemas.

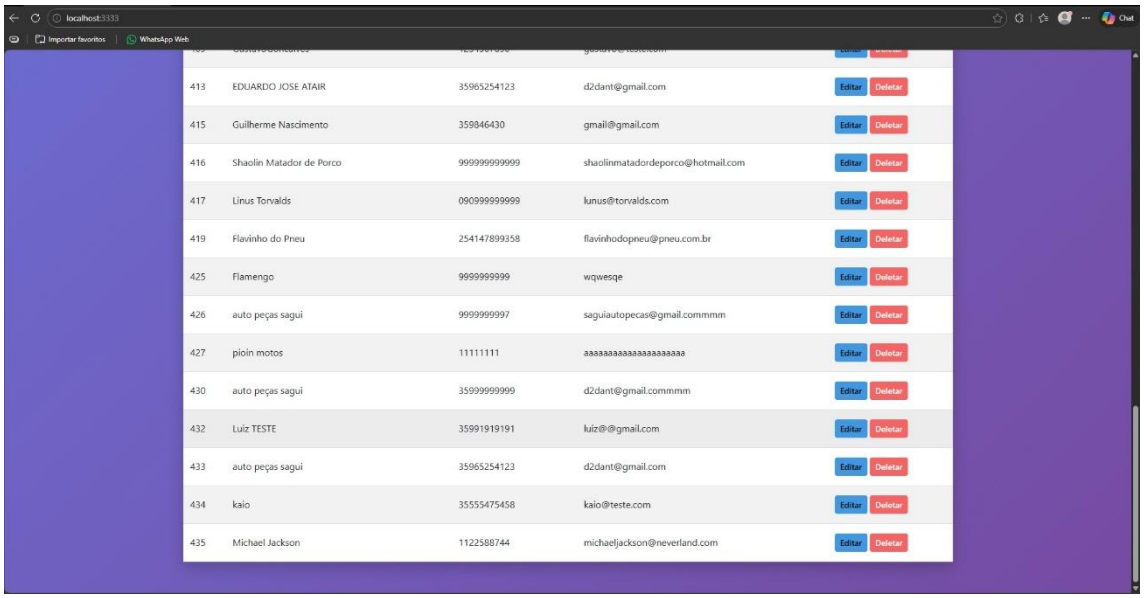
Conclusão

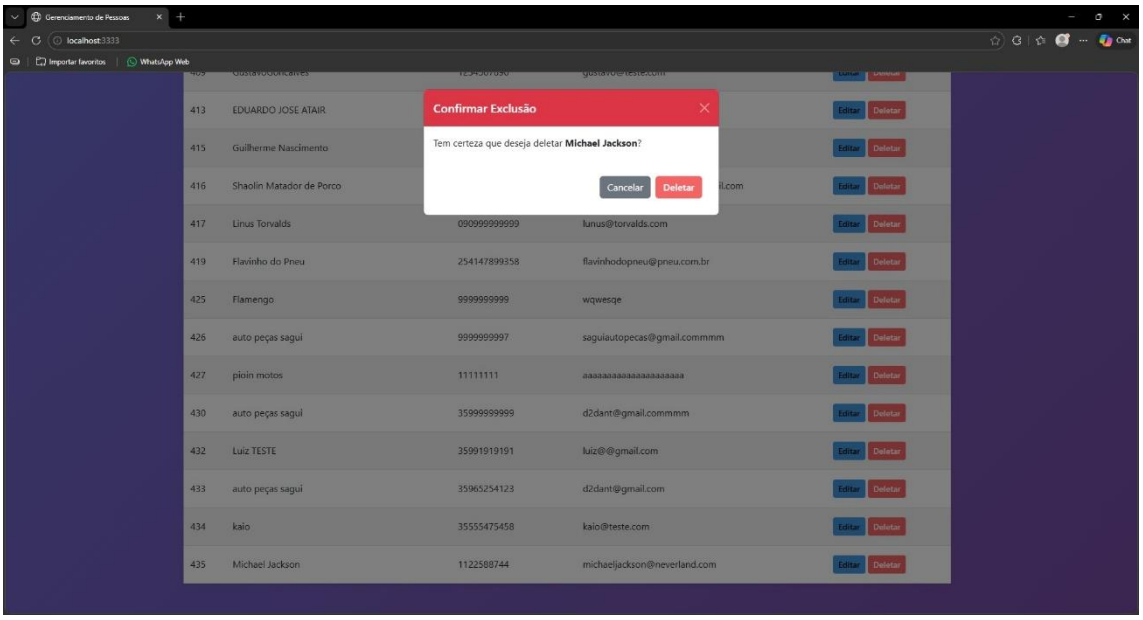
SQL Injection é uma falha séria, mas que pode ser evitada com práticas simples, como o uso de consultas preparadas. No código, isso foi feito, separando os comandos SQL dos dados enviados pelo usuário, tornando o sistema bem mais seguro contra esse tipo de ataque.

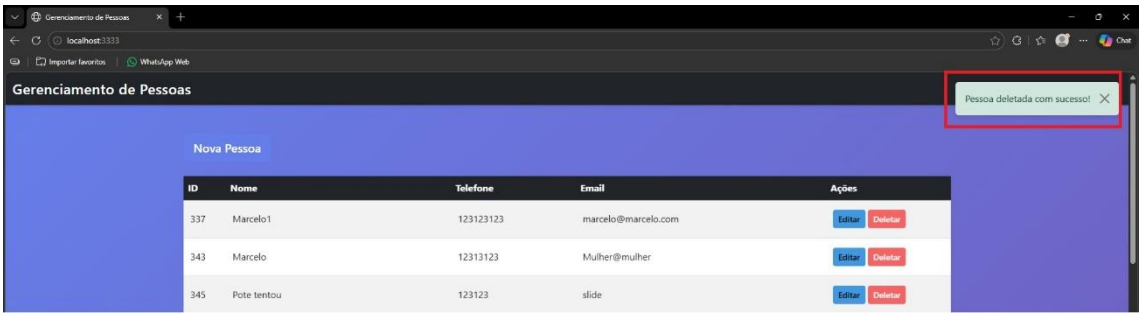
PRINTS


localhost:3333
Importar favoritos
WhatsApp Web
Gerenciamento de Pessoas
Nova Pessoa
ID Nome Telefone Email Ações
337 Marcelo1 123123123 marcelo@marcelo.com Editar Deletar
343 Marcelo 12313123 Mulher@mulher Editar Deletar
345 Pote tentou 123123 slide Editar Deletar
352 marcelao vegeta 123123 lucao a agachar Editar Deletar
354 Tulio 123123 VENDER A Editar Deletar
359 marcelão 123123 no banheiro Editar Deletar
363 Lucão Bezourudo 2424242424 lucao@bezouroalimenticio.com Editar Deletar
366 MARCELÃO 123123 PRA UM Editar Deletar
368 Marcelo Vegetta 123123 o indiano Editar Deletar
376 luiz teste novo 35999999999 d2dant@gmail.com Editar Deletar
378 decao teste novo 359999999 null Editar Deletar


Nova Pessoa
Nova Pessoa
Nome:
Michael Jackson
Telefone:
1122588744
Email:
michaeljackson@neverland.com
Salvar
Cancelar


localhost:3333
Importar favoritos
WhatsApp Web
413 EDUARDO JOSE ATAIR 35965254123 d2dant@gmail.com Editar Deletar
415 Guilherme Nascimento 359846430 gmail@gmail.com Editar Deletar
416 Shaolin Matador de Porco 999999999999 shaolinmatadordeporco@hotmail.com Editar Deletar
417 Linus Torvalds 090999999999 lunus@torvalds.com Editar Deletar
419 Flavinho do Pneu 254147899358 flavinhodopneu@pneu.com.br Editar Deletar
425 Flamengo 9999999999 wqwesqe Editar Deletar
426 auto peças sagui 9999999997 saguiautopecas@gmail.commmm Editar Deletar
427 pioin motos 11111111 aaaaaaaaaaaaaaaaaaaa Editar Deletar
430 auto peças sagui 35999999999 d2dant@gmail.commmm Editar Deletar
432 Luiz TESTE 35991919191 luiz@@gmail.com Editar Deletar
433 auto peças sagui 35965254123 d2dant@gmail.com Editar Deletar
434 kaio 35555475458 kaio@teste.com Editar Deletar
435 Michael Jackson 1122588744 michaeljackson@neverland.com Editar Deletar


Gerenciamento de Pessoas
localhost:3333
Importar favoritos
WhatsApp Web
Confirmar Exclusão
Tem certeza que deseja deletar **Michael Jackson**?
Cancelar
Deletar
413 EDUARDO JOSE ATAIR
415 Guilherme Nascimento
416 Shaolin Matador de Porco
417 Linus Torvalds 090999999999 lunus@torvalds.com
419 Flavinho do Pneu 254147899358 flavinhodopneu@pneu.com.br
425 Flamengo 9999999999 wqwesqe
426 auto peças saguí 9999999997 saguiautopecas@gmail.commmm
427 pioin motos 11111111 aaaaaaaaaaaaaaaaaaaa
430 auto peças saguí 35999999999 d2dant@gmail.commmm
432 Luiz TESTE 35991919191 luiz@@gmail.com
433 auto peças saguí 35965254123 d2dant@gmail.com
434 kaio 35555475458 kaio@teste.com
435 Michael Jackson 1122588744 michaeljackson@neverland.com
Editar
Deletar


Gerenciamento de Pessoas
localhost:3333
Importar favoritos
WhatsApp Web
Gerenciamento de Pessoas
Pessoa deletada com sucesso!
Nova Pessoa
ID Nome Telefone Email Ações
337 Marcelo1 123123123 marcelo@marcelo.com
343 Marcelo 12313123 Mulher@mulher
345 Pote tentou 123123 slide
Editar
Deletar